Conformity assessment methodologies

420-D04-AB Conformity Assessment - Day 5

Saturday, November 7, 2026 - 08:30-13:30 **EST** (Eastern Standard Time)

AEC (Attestation d'études collégiales) Cybersecurity - LEA.D8 - cohort CYB-01



Student edition

Cyber.SoHo Educational Hub
From the Industry to the Classroom — Building the IT's Future, Today and Together !

Legal notice and lab rules

LAB — Authorized, isolated lab use only: your two **VMs** (virtual machines), your lab subnet, the fictional case

Legal Notice 6.4, 7.6

6.1 — Written authorization before any monitoring, scanning or testing

Legal Notice 6.1, Annex D

DATA — Fictional data only; mask anything that looks like personal information

Legal Notice 6.7, 18.2

7.5 — Standards are cited, not copied; course work is not an audit or legal advice

Legal Notice 7.5, 8.1, 16

17 — No recording of sessions; quizzes and solutions are not shared

Legal Notice 17

VT — Check every link and download with VirusTotal before opening it

Legal Notice 14, Annex C

Full text: **Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy** - Criminal Code of Canada s. 342.1 (unauthorized use of a computer)

Today's agenda

08:30-08:45

Recall of Day 4 (asset inventory and classification)

08:45-09:45

Lecture: Lessons 1-6 (about 10 minutes each)

09:45-11:30

Lab block 1: finish Lab 2 Part A, start Part B

11:30-11:40

Break

11:40-13:30

Lab block 2: Lab 2 Part B and Practice Quiz #1

Next: Mid-Term on Day 6, Tuesday, November 10, at 18:30. Lab 2 is due Sunday, November 15, 23:59 **EST** (Omnivox **LÉA** (Omnivox classroom module) DropBox).

BY THE END OF THE MORNING YOU CAN

Learning objectives

1. Choose the audit method that fits a requirement
2. Build a reproducible, documented sample
3. Define a test: requirement, method, sample, pass rule, evidence
4. Select 12-15 checklist items with rules; map to 4 frameworks
5. Rate a finding with the 3x3 matrix and justify it
6. Schedule Days 7-10 within the constraints, after a signed mandate
7. Assemble the six sections of the Lab 2 Part B plan

Recall of Day 4 (1/2)

1. 12 inventory columns: identification, classification, maintenance
2. Owner (accountable) vs custodian (operates); empty owner = finding
3. 4 sensitivity levels + 2 flags (**PI** (personal information), **CHD** (cardholder data)); decision table in order
4. Frameworks: **CIS** (Center for Internet Security) 1.1, 2.1, 3.2 - **ISO** (International Organization for Standardization) A.5.9, A.5.12 - **CSF** (Cybersecurity Framework) ID.AM - PCI 12.5.1

R

KEY MESSAGE

Inventory and classification feed the plan.

WHERE YOU USE IT

Lab 2 Part A (finish it today) and Part B: the critical assets become the scope of the plan.

Recall of Day 4 (2/2)

1. **SPOF** (single point of failure): the payment provider supports online and in-store sales
2. Keep it current: review every 90 days and after each change; reconcile both ways
3. Today: the 5 critical assets + 2 **VMs** (virtual machines) become the scope of the plan
4. Questions: owner of DB-RDS01? first question of the decision table? why the provider?

R

KEY MESSAGE

Critical assets = scope of the plan.

WHERE YOU USE IT

Lab 2 Part A (finish it today) and Part B: the critical assets become the scope of the plan.

1

Lesson 1 - Audit methods and techniques

Course plan topic: Audit methods and techniques (e.g., sampling, walkthroughs, observations)

References today: **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-53A Rev. 5, **PCI DSS** (Payment Card Industry Data Security Standard) v4.0.1, **ISO** (International Organization for Standardization) 19011:2026

WORKED EXAMPLE

Choosing which laptops to test: a reproducible sampling plan for MC-03

VIDEO - 2:49

Audits and Assessments - CompTIA Security+ SY0-701 - 5.5 (Professor Messer)

Open on YouTube

VIDEO - ≈ 7 min (estimate)

9 Types of Audit Procedures and Evidence (Edspira)

Open on YouTube

Criteria, evidence and findings

1. Audit criteria = requirements used as the reference (Lab 1)
2. Audit evidence = verifiable information relevant to a criterion
3. Audit method = the defined way evidence is collected
4. Finding = conformity, nonconformity or observation
5. A finding without evidence is an opinion

1 KEY MESSAGE

Criteria -> methods -> evidence -> findings.

WHERE YOU USE IT

Lab 2 Part B step 4 (the sample column of your checklist), Lab 3 Part B on Day 8 (patch status) and Project section 5 (methodology).

Six audit methods (1/2)

1. Document review: what is supposed to happen?
2. Interview: what do people say happens?
3. Walkthrough: one real case, start to end, with the performer
4. Example: one new-employee request, **HR** (Human Resources) form -> **AD** (Active Directory) account

1 KEY MESSAGE

Documents say, people say, the walkthrough shows.

WHERE YOU USE IT

Lab 2 Part B step 4 (the sample column of your checklist), Lab 3 Part B on Day 8 (patch status) and Project section 5 (methodology).

Six audit methods (2/2)

1. Observation: watch an activity as it happens
2. Sampling: test a subset with a stated rule
3. Re-performance: the auditor runs the check personally
4. Strongest evidence: re-performance + corroboration

1 KEY MESSAGE

Observation, sampling, re-performance.

WHERE YOU USE IT

Lab 2 Part B step 4 (the sample column of your checklist), Lab 3 Part B on Day 8 (patch status) and Project section 5 (methodology).

Same methods, three references

1. **NIST SP** 800-53A Rev. 5: examine, interview, test (+ depth, coverage)
2. **PCI DSS** v4.0.1 testing procedures: examine, observe, interview
3. **ISO** 19011:2026 (May 2026): document review, interview, observation, sampling, remote methods
4. One vocabulary for Lab 2 Part B

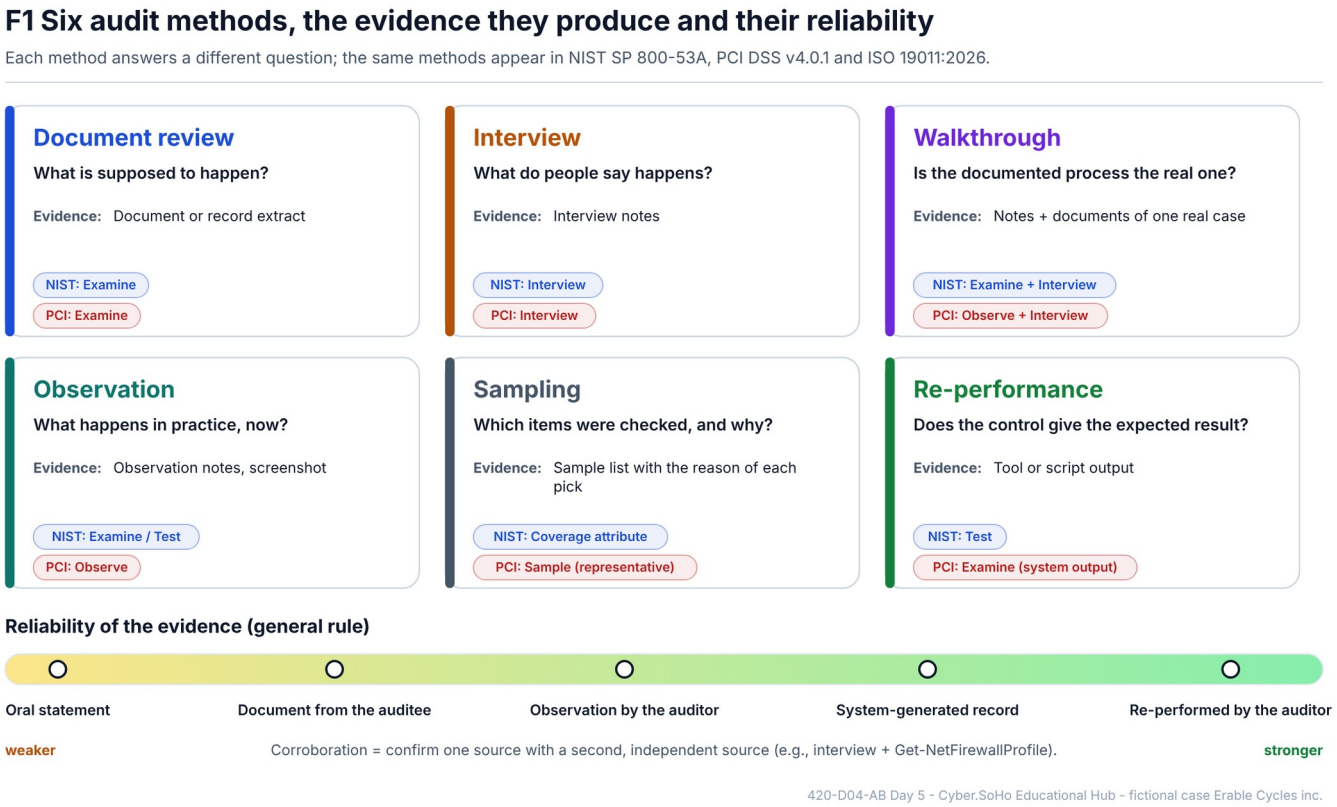


Figure F1. Different words, same methods.

Sampling: population and sample

1. Population = all items the requirement applies to
2. Sample = the items tested; sampling unit = one item
3. Judgement-based: chosen by risk, not generalizable
4. Statistical: random, known probability, generalizable
5. Sampling risk: sample conclusion differs from 100 % test

1 KEY MESSAGE

Judgement for risk, random for generalization.

WHERE YOU USE IT

Lab 2 Part B step 4 (the sample column of your checklist), Lab 3 Part B on Day 8 (patch status) and Project section 5 (methodology).

A reproducible sampling plan for MC-03

1. J1: 3 laptops with local admin rights
2. J2: one laptop per site, oldest update
3. R: 5 random picks, seed 20261107
4. Result: 10 of 45 = 22 %, every pick with a reason
5. **PCI DSS**: cover every variant, or test 100 %

KEY LINES - L1_sampling_plan.py

```
SEED = 20261107
rng = random.Random(SEED)
random_picks = rng.sample(remaining,
SAMPLE_SIZE - len(selected))
print("Random picks:", ",
".join(sorted(random_picks)))
```

KEY MESSAGE **Write the rule, the size and the reason of every pick.**

Evidence quality and the audit life cycle

1. Sufficient, reliable, relevant
2. Reliability: independent, original, system-generated, obtained by the auditor
3. Corroboration: two independent sources
4. **ISO** 19011 cycle: initiate -> prepare -> conduct -> report -> complete -> follow up
5. Today = prepare (the plan)

1 KEY MESSAGE

Prepare today, conduct in Lab 3.

WHERE YOU USE IT

Lab 2 Part B step 4 (the sample column of your checklist), Lab 3 Part B on Day 8 (patch status) and Project section 5 (methodology).

2

Lesson 2 - Selection and application of appropriate tests

Course plan topic: Selection and application of appropriate tests

References today: **PCI DSS** (Payment Card Industry Data Security Standard) v4.0.1, **CIS** (Center for Internet Security) Controls v8.1, **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27001:2022, **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0

WORKED EXAMPLE

One complete test: MC-03 patch level on LAB-WIN11

VIDEO - Short, under 1 min

Master Cybersecurity Control Testing: 3 Testing Techniques (Short) (Simply Cyber - Gerald Auger, PhD)

Open on YouTube

VIDEO - ≈ 6 min (estimate)

How to Test Internal Controls (Edspira)

Open on YouTube

A test has five parts

1. Requirement (criterion)
2. Method
3. Sample
4. Expected result = pass rule
5. Evidence to keep
6. After execution: actual result, verdict, evidence reference

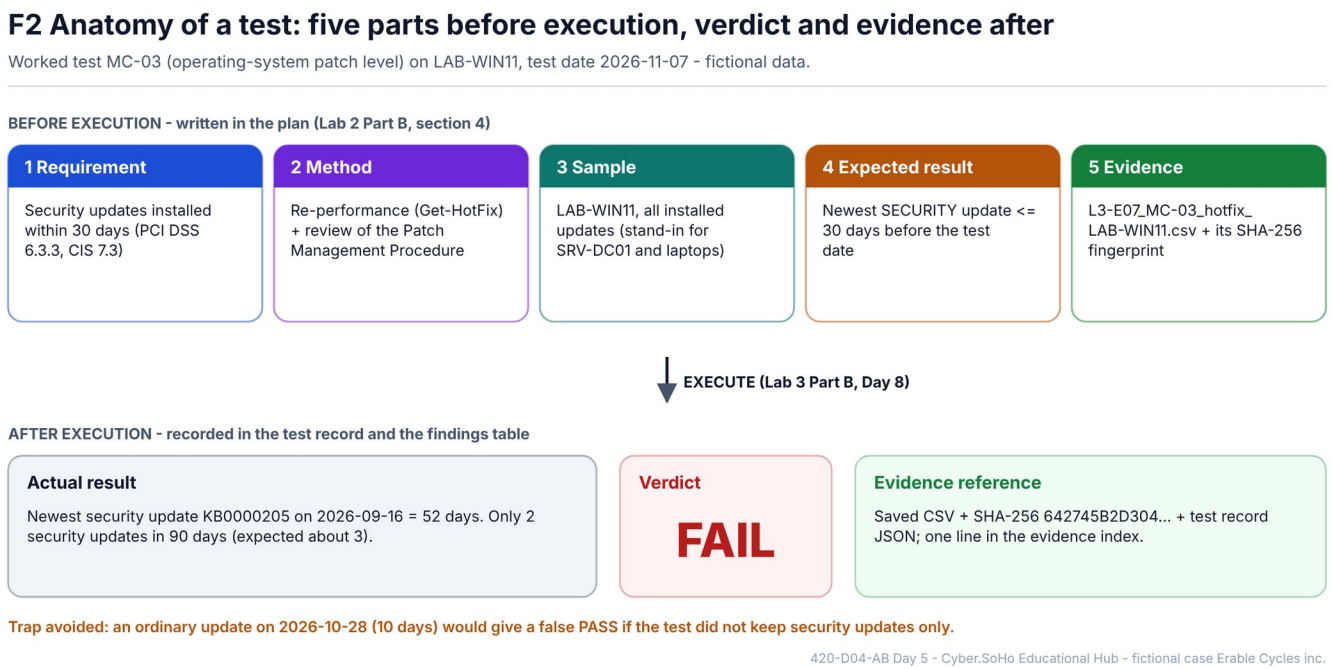


Figure F2. Define all five parts before testing.

The verb chooses the method

1. documented / approved -> document review
2. performed every N months -> records + sampling
3. configured / enabled -> re-performance
4. only approved ports -> reachability test + rule review
5. Important items: two methods (corroboration)

2 KEY MESSAGE

Read the verb, pick the method.

WHERE YOU USE IT

Lab 2 Part B step 4 (test definitions) and Lab 3 Part B on Day 8 (patch status of both **VMs** (virtual machines)); Course Procedure Manual chapter 4.

Automated and manual tests

1. Automated: fast, repeatable, 100 % of known settings
2. False positive / false negative
3. Tool coverage: **CIS-CAT** (CIS Configuration Assessment Tool) Lite has no Ubuntu 24.04 -> Lynis
4. Manual: policies, people, physical controls

2 KEY MESSAGE

Tools test; auditors interpret.

WHERE YOU USE IT

Lab 2 Part B step 4 (test definitions) and Lab 3 Part B on Day 8 (patch status of both **VMs** (virtual machines)); Course Procedure Manual chapter 4.

Design vs operating effectiveness

1. Design: the control as described would meet the requirement
2. Operating effectiveness: the control worked over a period
3. One screenshot = existence at one moment
4. Example: monthly updates over 90 days

2 KEY MESSAGE

Existence is not operation over time.

WHERE YOU USE IT

Lab 2 Part B step 4 (test definitions) and Lab 3 Part B on Day 8 (patch status of both **VMs** (virtual machines)); Course Procedure Manual chapter 4.

Measurable pass rules

1. Not measurable: 'patching is good'
2. Measurable: newest security update <= 30 days old
3. **PCI DSS** 6.3.3: critical updates within one month
4. '**N/A** (not applicable) - reason' and 'Not tested - reason' are acceptable
5. An invented result is never acceptable

2 KEY MESSAGE

If it cannot be measured, it cannot be tested.

WHERE YOU USE IT

Lab 2 Part B step 4 (test definitions) and Lab 3 Part B on Day 8 (patch status of both **VMs** (virtual machines)); Course Procedure Manual chapter 4.

Worked test: MC-03 on LAB-WIN11

1. Newest security update: Sept 16 -> 52 days -> FAIL
2. Only 2 security updates in 90 days: October missing
3. Trap: Oct 28 ordinary update would give a false PASS
4. Evidence saved, **SHA-256** (Secure Hash Algorithm, 256-bit) computed, test card saved as **JSON** (JavaScript Object Notation)

KEY LINES - L2_Test-PatchLevel.ps1

```
$Security = $Updates | Where-Object
{ $_.Description -match "Security" } | Sort-
Object InstalledOn -Descending

$AgeDays = ($TestDate -
$Newest.InstalledOn).Days

$Result = if ($AgeDays -le $MaxAgeDays)
{ "PASS" } else { "FAIL" }

$Hash = (Get-FileHash -Path $EvidenceFile -
Algorithm SHA256).Hash
```

KEY MESSAGE **A precise procedure avoids a false PASS.**

Evidence handling

1. Naming rule: L3-E07_MC-03_hotfix_LAB-WIN11.csv
2. Date of collection + **SHA-256** fingerprint
3. Mask real personal information (Legal Notice 6.7, 18.2)
4. One line per file in the evidence index
5. Test once, satisfy many: **CIS** 7.3, **ISO** (International Organization for Standardization) A.8.8, PCI 6.3.3, **CSF** PR.PS-02

2 KEY MESSAGE

Named, dated, fingerprinted, masked, indexed.

WHERE YOU USE IT

Lab 2 Part B step 4 (test definitions) and Lab 3 Part B on Day 8 (patch status of both **VMs** (virtual machines)); Course Procedure Manual chapter 4.

3

Lesson 3 - Development of audit checklists aligned to frameworks

Course plan topic: Development of audit checklists aligned to frameworks (e.g., **ISO** (International Organization for Standardization) 27001 clauses)

References today: **CIS** (Center for Internet Security) Controls v8.1, **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27001:2022, **PCI DSS** (Payment Card Industry Data Security Standard) v4.0.1, **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0, **ISO/IEC TS** (Technical Specification) 27008

WORKED EXAMPLE

Building the Lab 2 Part B checklist with written rules

VIDEO - ≈ 10 min (estimate)

ISO 27001 Internal Audit Essentials: Everything You Need to Know (Dejan Kosutic (Advisera))

Open on YouTube

VIDEO - ≈ 10 min (estimate)

How to Use CIS Hosted CSAT To Assess Security Controls' Implementation (NetSec)

Open on YouTube

Why an audit checklist

1. Complete: nothing in scope forgotten
2. Consistent: every auditor tests the same way
3. Repeatable: results comparable next year
4. Evidence planned in advance
5. Judgement still applies: observations outside the list

3 KEY MESSAGE

The checklist guides; judgement stays.

WHERE YOU USE IT

Lab 2 Part B step 3 (your checklist), Lab 3 Parts A-C (the items you test) and Project section 5. The output file feeds the Lesson 5 scheduling example.

Anatomy of a checklist line

1. ID, item, type (C, T, A, S)
2. References: **CIS** v8.1, **ISO/IEC** 27001:2022, **PCI DSS** v4.0.1, **NIST CSF** 2.0
3. Requirement in our own words
4. Test procedure, method, sample
5. Expected result, expected evidence, result, notes

F3 Anatomy of one checklist line: MC-03 operating-system patch level

Same fields on every line; references are cited by number, the requirement is written in our own words.

ID / item / type	MC-03 Operating-system patch level - type C (configuration)	Identification
CIS Controls v8.1	7.3 (IG1)	Crosswalk
ISO/IEC 27001:2022	A.8.8	
PCI DSS v4.0.1	6.3.3	
NIST CSF 2.0	PR.PS-02	
Requirement (own words)	Security updates are installed within the period set by policy (critical updates: one month).	What must be true
Test procedure / method	Windows: Get-HotFix and Windows Update history. Ubuntu: apt list --upgradable, unattended-upgrades status, /var/log/apt/history.log. Compare with the Patch Management Procedure.	How it is tested
Sample	Both VMs; in a real audit 10 of the 45 laptops (judgement + random)	
Expected result	Newest security update <= 30 days old; no security update pending for more than 30 days; automatic updates on	Pass rule + evidence
Expected evidence	Script output (CSV) and screenshots	
Result / notes	Filled in Lab 3 after testing (PASS, FAIL, N/A - reason, Not tested - reason)	After testing

420-D04-AB Day 5 - Cyber.SoHo Educational Hub - fictional case Erable Cycles inc.

Figure F3. Same fields on every line.

The crosswalk

1. One line, four references -> one test serves four frameworks
2. **CIS** mappings to **NIST CSF** 2.0 and **ISO/IEC** 27001
3. Tools: **CIS CSAT** (free), CISO Assistant (open source)
4. '-' when a framework does not apply (MC-11 PCI)
5. **ISO** text licensed: cite numbers only

3 KEY MESSAGE

Map honestly; cite, do not copy.

WHERE YOU USE IT

Lab 2 Part B step 3 (your checklist), Lab 3 Parts A-C (the items you test) and Project section 5. The output file feeds the Lesson 5 scheduling example.

The Master Checklist: 20 items

1. 8 configuration items MC-01 to MC-08 -> Lab 3 Parts A-B
2. 7 technical controls MC-09 to MC-15
3. 3 administrative controls MC-16 to MC-18
4. 2 segmentation / access MC-19, MC-20
5. T, A, S -> Lab 3 Part C

3 KEY MESSAGE

8 C + 7 T + 3 A + 2 S = 20.

WHERE YOU USE IT

Lab 2 Part B step 3 (your checklist), Lab 3 Parts A-C (the items you test) and Project section 5. The output file feeds the Lesson 5 scheduling example.

Five selection rules (1/2)

1. The item tests an in-scope asset
2. Legal / contractual items: MC-12, MC-18, MC-19, MC-20
3. One baseline per platform: MC-01, MC-02, MC-08

3 KEY MESSAGE

Law first, then baselines.

WHERE YOU USE IT

Lab 2 Part B step 3 (your checklist), Lab 3 Parts A-C (the items you test) and Project section 5. The output file feeds the Lesson 5 scheduling example.

Five selection rules (2/2)

4. Every in-scope asset tested at least once
5. At least 3 configuration and 3 control items

- Fill by priority: 2 per critical asset, 1 per **VM** (virtual machine)
- Example result: 14 items, 8 C + 6 controls

3 KEY MESSAGE

Rules first, priority second.

WHERE YOU USE IT

Lab 2 Part B step 3 (your checklist), Lab 3 Parts A-C (the items you test) and Project section 5. The output file feeds the Lesson 5 scheduling example.

Measuring coverage

1. References per framework: 14/14 for **CIS**, **ISO**, PCI, **CSF**
2. Tests per asset: A01 9, V01 10, V02 10
3. A04, A07, A10: one item each
4. Option: add MC-14 or MC-15 for the database

3 KEY MESSAGE

Measure coverage, then decide.

WHERE YOU USE IT

Lab 2 Part B step 3 (your checklist), Lab 3 Parts A-C (the items you test) and Project section 5. The output file feeds the Lesson 5 scheduling example.

4

Lesson 4 - Risk analysis fundamentals for assessing impact and likelihood

Course plan topic: Risk analysis fundamentals for assessing impact and likelihood

References today: **ISO** (International Organization for Standardization) 31000:2018, **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27005:2022, **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-30 Rev. 1, **CIS RAM** (CIS Risk Assessment Method)

WORKED EXAMPLE

Calibrating seven practice findings with the 3x3 matrix

VIDEO - 9:13

Risk Analysis - CompTIA Security+ SY0-701 - 5.2 (Professor Messer)

Open on YouTube

VIDEO - ≈ 5 min (estimate)

Risk and How to use a Risk Matrix (Let's Learn Public Health)

Open on YouTube

Risk vocabulary

1. Risk = effect of uncertainty on objectives (**ISO** 31000)
2. In practice: likelihood x impact of an event
3. Threat exploits a vulnerability of an asset
4. Control modifies risk; compensating control
5. Inherent risk vs residual risk

4 KEY MESSAGE

Threat + vulnerability + asset = risk event.

WHERE YOU USE IT

Lab 2 Part B step 5 (risk method), Lab 3 Part B on Day 8 (findings table) and Project section 7 (rating of the 8-10 findings).

Qualitative or quantitative

1. Qualitative: Low, Medium, High in words
2. Semi-quantitative: 1, 2, 3 multiplied
3. Quantitative: **SLE** (single loss expectancy) = value x exposure factor; **ALE** (annualized loss expectancy) = **SLE** x **ARO** (annualized rate of occurrence)
4. Example: **SLE** $6,000 x **ARO** 0.5 = **ALE** $3,000 / year
5. Course choice: semi-quantitative 3x3

4 KEY MESSAGE

ALE = SLE x ARO; the course uses 3x3.

WHERE YOU USE IT

Lab 2 Part B step 5 (risk method), Lab 3 Part B on Day 8 (findings table) and Project section 7 (rating of the 8-10 findings).

The course 3x3 matrix

1. Score = likelihood (1-3) x impact (1-3)
2. 1-2 Low
3. 3-4 Medium
4. 6 High
5. 9 Critical

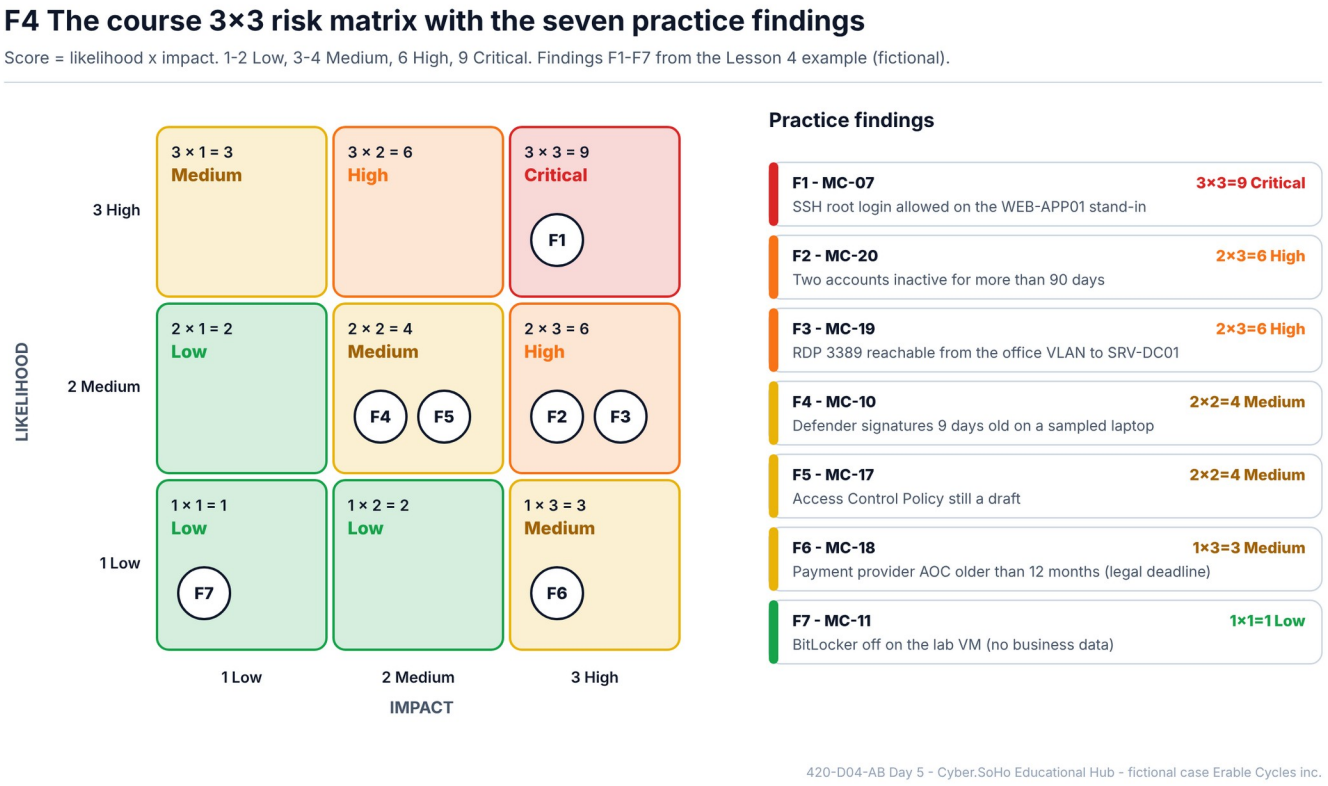


Figure F4. Learn the score-to-level rule.

One-line scales (1/2): likelihood

1. Low - physical access, unlikely conditions, or strong compensating control
2. Medium - internal access or specific condition, partial compensating control
3. High - Internet or any employee, already exploited, no compensating control

4 KEY MESSAGE

Exposure and compensating controls set the likelihood.

WHERE YOU USE IT

Lab 2 Part B step 5 (risk method), Lab 3 Part B on Day 8 (findings table) and Project section 7 (rating of the 8-10 findings).

One-line scales (2/2): impact

1. Low - inconvenience only, no legal duty
2. Medium - process degraded > 1 day with a workaround, or internal data exposed
3. High - legal duty breached (**PIPEDA** (Personal Information Protection and Electronic Documents Act), Law 25, **PCI DSS** (Payment Card Industry Data Security Standard)) or High-impact process stopped

- Same criteria as the Day 4 business impact

4 KEY MESSAGE

Legal duty breached = impact 3.

WHERE YOU USE IT

Lab 2 Part B step 5 (risk method), Lab 3 Part B on Day 8 (findings table) and Project section 7 (rating of the 8-10 findings).

Rating a finding

- Describe: condition, criterion, cause, effect

1. Asset and business impact from the inventory
2. Likelihood with the scale
3. Impact with the scale
4. Score and level
5. One-sentence justification

4 KEY MESSAGE

Describe first, rate second, justify always.

WHERE YOU USE IT

Lab 2 Part B step 5 (risk method), Lab 3 Part B on Day 8 (findings table) and Project section 7 (rating of the 8-10 findings).

Calibration: seven practice findings

1. F1 **SSH** (Secure Shell) root login (MC-07): 3x3 = Critical
2. F2 dormant accounts, F3 **RDP** (Remote Desktop Protocol) to the **DC** (domain controller): 2x3 = High
3. F4, F5: 2x2 = Medium
4. F6 provider **AOC** (Attestation of Compliance) > 12 months: 1x3 = Medium, legal deadline
5. F7 BitLocker off on lab **VM** (virtual machine): 1x1 = Low

KEY LINES - L4_risk_calibration.html

```
function level(score) { return score <= 2 ?
"Low" : score <= 4 ? "Medium" : score <= 6 ?
"High" : "Critical"; }

for (const f of findings) { f.score = f.L *
f.I; f.level = level(f.score); }

findings.sort((a, b) => b.score - a.score ||
(b.legal - a.legal) ||
a.id.localeCompare(b.id));
```

KEY MESSAGE **1 Critical, 2 High, 3 Medium, 1 Low.**

Using risk before and after testing

1. Before: test critical assets first, with more depth
2. After: rate every nonconformity, order the findings
3. **ISO/IEC** 27005:2022 treatment: modification, retention, avoidance, sharing
4. The risk owner decides, not the auditor
5. References: **ISO/IEC** 27005, **NIST SP** 800-30 Rev. 1, **CIS RAM**

4 KEY MESSAGE

Auditors rate; owners decide.

WHERE YOU USE IT

Lab 2 Part B step 5 (risk method), Lab 3 Part B on Day 8 (findings table) and Project section 7 (rating of the 8-10 findings).

5

Lesson 5 - Scheduling and planning compliance assessment activities

Course plan topic: Scheduling and planning compliance assessment activities

References today: **ISO** (International Organization for Standardization) 19011:2026, **ISO/IEC** (International Organization for Standardization / International Electrotechnical Commission) 27001:2022 clause 9.2.2, **ISO/IEC** 27002:2022 control 8.34, **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-115

WORKED EXAMPLE

Placing the checklist on the Lab 3 calendar with constraint checks

VIDEO - ≈ 6 min (estimate)

How to establish an audit program according to ISO 19011:2018 (Scilife)

Open on YouTube

VIDEO - ≈ 10 min (estimate)

Conducting Management System's Audit Opening Meeting (Akinwale Akindiya - Training Consultant)

Open on YouTube

Audit programme and audit plan

1. Programme: one or more audits over a period, for a purpose
2. Example: yearly programme of Erable Cycles
3. Plan: activities and arrangements of one audit
4. Lab 2 Part B = the plan of the Lab 3 assessment

5 KEY MESSAGE

Programme = several audits; plan = one audit.

WHERE YOU USE IT

Lab 2 Part B step 6 (schedule) and step 7 (meetings); Lab 3 on Days 7-10; Project section 5.

ISO/IEC 27001:2022 clause 9.2.2

1. Plan and maintain an internal audit programme
2. Frequency, methods, responsibilities, planning, reporting
3. Consider importance of processes and previous results
4. Criteria and scope for each audit; objective, impartial auditors
5. Report results to management

5 KEY MESSAGE

The standard requires a planned programme.

WHERE YOU USE IT

Lab 2 Part B step 6 (schedule) and step 7 (meetings); Lab 3 on Days 7-10; Project section 5.

What an audit plan contains

1. Objectives, scope, criteria
2. Methods and samples
3. Schedule: dates, times, places
4. Roles, resources, communication
5. Report format and confidentiality

5 KEY MESSAGE

Six sections, four to five pages.

WHERE YOU USE IT

Lab 2 Part B step 6 (schedule) and step 7 (meetings); Lab 3 on Days 7-10; Project section 5.

The mandate comes first

1. Written authorization from the person with authority
2. Systems, activities, exclusions, period, contact, signature
3. Legal Notice 6.1 + Annex D template
4. Criminal Code s. 342.1: unauthorized use of a computer
5. **ISO/IEC** 27002 8.34; **NIST SP** 800-115 rules of engagement

5 KEY MESSAGE

No signature, no test.

WHERE YOU USE IT

Lab 2 Part B step 6 (schedule) and step 7 (meetings); Lab 3 on Days 7-10; Project section 5.

Constraints and dependencies

1. Business hours 09:00-18:00 Mon-Sat -> scans after 18:00
2. Change freeze Nov 20-30 (Black Friday, Cyber Monday)
3. Order: Part A tools -> Part B scripts -> Part C controls
4. Preconditions: signed mandate, **VM** (virtual machine) snapshots (Legal 6.4)

5 KEY MESSAGE

Hours, freeze, order, preconditions.

WHERE YOU USE IT

Lab 2 Part B step 6 (schedule) and step 7 (meetings); Lab 3 on Days 7-10; Project section 5.

The Lab 3 calendar

1. Day 7 Wed Nov 11: kick-off + Part A (MC-01, MC-02, MC-08)
2. Day 8 Sat Nov 14: Part B (MC-03 to MC-07)
3. Day 9 Tue Nov 17: Part C (controls, MC-19 scan at 19:45)
4. Day 10 Wed Nov 18: finish + closing meeting
5. Calendar file: 5 events

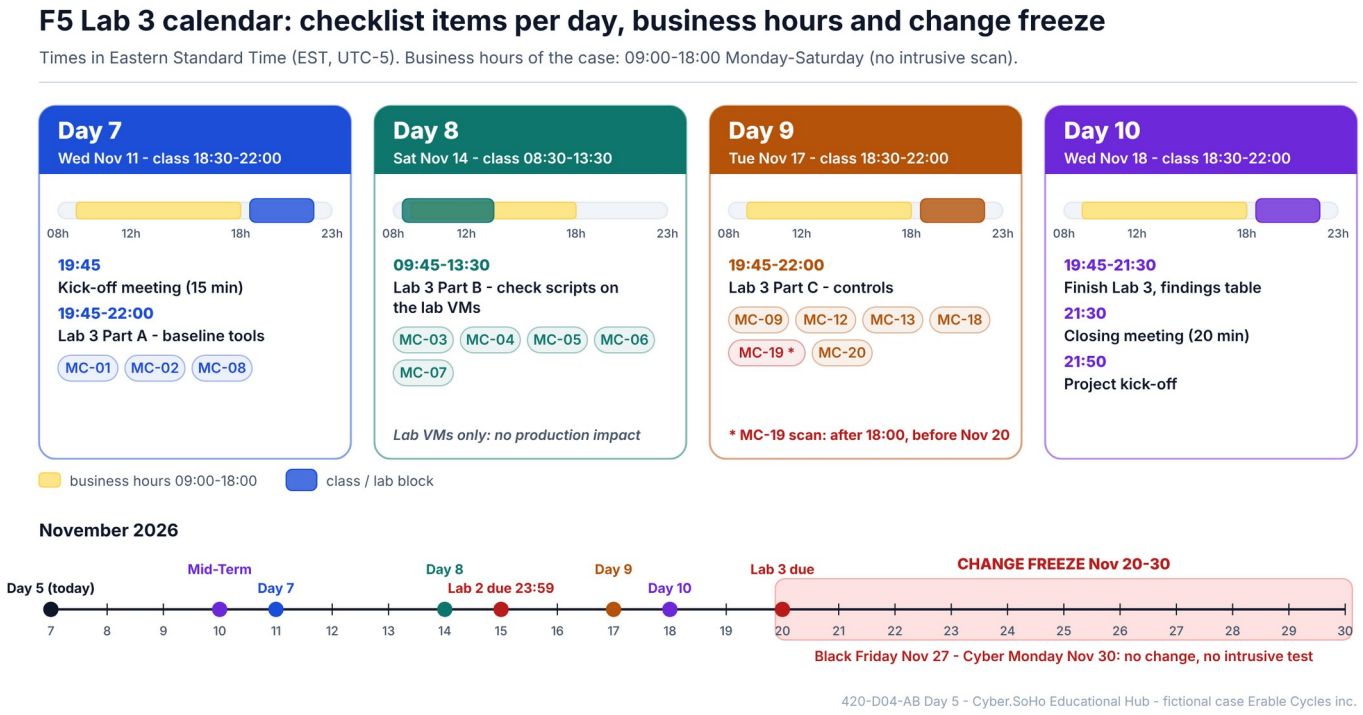


Figure F5. Every item has a day, a time and a tool.

Opening and closing meetings

1. Opening: confirm plan and schedule
2. Opening: confirm mandate, constraints, contacts; agree communication
3. Closing: present findings with ratings
4. Closing: confirm facts, note disagreements
5. Closing: agree dates of report and corrective actions

5 KEY MESSAGE

Three bullets for each meeting.

WHERE YOU USE IT

Lab 2 Part B step 6 (schedule) and step 7 (meetings); Lab 3 on Days 7-10; Project section 5.

6

Lesson 6 - From plan to evidence: the Lab 2 Part B deliverable

Course plan topic: Synthesis - the assessment plan, Lab 2 summary and Mid-Term preparation

References today: Lab 2 template (**XLSX**), plan template (**DOCX**), Part B rubric, Legal Notice Annex D

WORKED EXAMPLE

Readiness check of a draft assessment plan

VIDEO - 11:36

Third-party Risk Assessment - CompTIA Security+ SY0-701 - 5.3 (Professor Messer)

Open on YouTube

VIDEO - ≈ 3 min (estimate)

The Rules of Engagement For Performing Penetration Testing (Appknox)

Open on YouTube

The plan joins five lessons

1. Scope <- Part A: 5 critical assets + 2 **VMs** (virtual machines)
2. Mandate <- authorization letter (Annex D)
3. Checklist <- Lesson 3 rules
4. Tests <- Lessons 1 and 2
5. Risk method <- Lesson 4
6. Schedule and meetings <- Lesson 5

6 KEY MESSAGE

One source of information, two files.

WHERE YOU USE IT

Lab 2 Part B deliverable (due Sunday, November 15, 23:59 **EST** (Eastern Standard Time)), Project sections 2 and 5, Course Procedure Manual chapters 2 and 3.

From plan to evidence

1. Each item -> a test record in Lab 3
2. Evidence: naming rule + **SHA-256** (Secure Hash Algorithm, 256-bit) + evidence index
3. Nonconformity -> finding (condition, criterion, cause, effect)
4. Rated with the section 5 matrix
5. Good plan = Lab 3 is execution

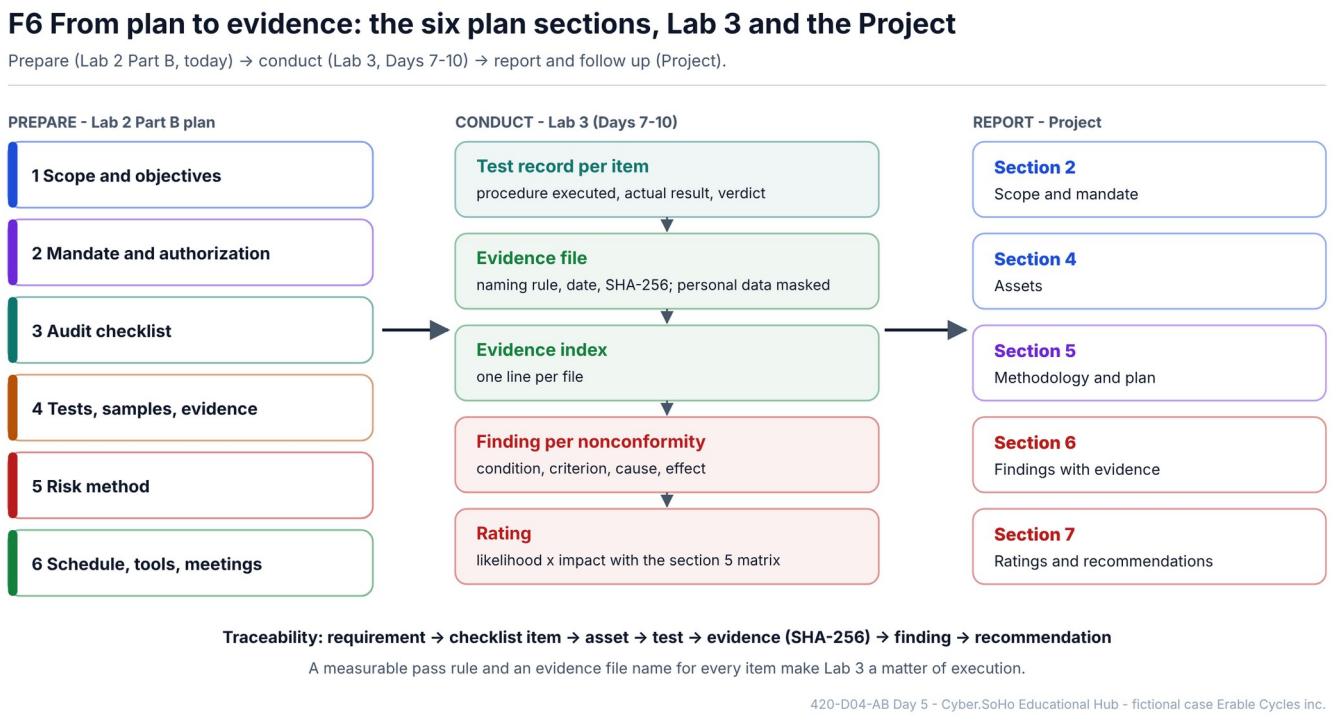


Figure F6. The plan decides the quality of Lab 3.

Readiness check: the Part B rubric

1. Scope and mandate: 1
2. Checklist quality and mapping: 2
3. Test methods and evidence: 1
4. Risk scales and schedule: 1
5. Example draft: 4.5 / 5 - mandate not dated

6 KEY MESSAGE

Check against the rubric before submitting.

WHERE YOU USE IT

Lab 2 Part B deliverable (due Sunday, November 15, 23:59 **EST** (Eastern Standard Time)), Project sections 2 and 5, Course Procedure Manual chapters 2 and 3.

Common mistakes in Lab 2 Part B

1. Mandate not signed or not dated
2. Items without framework references
3. Pass rule not measurable ('firewall OK')
4. Sample without size or reason
5. Scan during business hours or after Nov 20
6. Asset IDs that change between Part A and Part B
7. Copied **ISO** (International Organization for Standardization) text (Legal Notice 7.5) or real personal information (6.7)

6 KEY MESSAGE

Signed, mapped, measurable, justified, traceable.

WHERE YOU USE IT

Lab 2 Part B deliverable (due Sunday, November 15, 23:59 **EST** (Eastern Standard Time)), Project sections 2 and 5, Course Procedure Manual chapters 2 and 3.

Lab 2 in summary

1. Part A (5 pts): 12 assets x 12 columns, **VM** (virtual machine) evidence, classification, 5 critical assets
2. Part B (5 pts): six-section plan + signed authorization letter
3. Submit 2 files: ..._Lab2.xlsx and ..._Lab2.pdf
4. Omnivox **LÉA** (Omnivox classroom module) DropBox - Sun Nov 15, 2026, 23:59 **EST** (Eastern Standard Time)
5. Weight: 10 %

6 KEY MESSAGE

Due Sunday Nov 15, 23:59 EST.

WHERE YOU USE IT

Lab 2 Part B deliverable (due Sunday, November 15, 23:59 **EST** (Eastern Standard Time)), Project sections 2 and 5, Course Procedure Manual chapters 2 and 3.

Mid-Term preparation

1. Day 6, Tue Nov 10, 18:30 - 90 minutes - 20 %
2. 25 **MCQ** (multiple-choice question) + 15 **MSQ** (number of answers in brackets)
3. Intro 8, laws 12, frameworks 8, assets 6, methodologies 6
4. About 2.25 minutes per question
5. Study: flashcards, lesson questions, practice tests

6 KEY MESSAGE

Tuesday 18:30, 40 questions, 90 minutes.

WHERE YOU USE IT

Lab 2 Part B deliverable (due Sunday, November 15, 23:59 **EST** (Eastern Standard Time)), Project sections 2 and 5, Course Procedure Manual chapters 2 and 3.

Next steps and official references

1. Lab 2 due Sun Nov 15, 23:59 **EST** (Eastern Standard Time) - Omnivox **LÉA** (Omnivox classroom module) DropBox
2. Mid-Term: Day 6, Tue Nov 10, 18:30 (25 **MCQ** (multiple-choice question) + 15 **MSQ** (multiple-select question), 90 min)
3. Day 7, Wed Nov 11: kick-off + Lab 3 Part A (signed mandate first)
4. Practice Quiz #1: second lab block today

OFFICIAL REFERENCES (click to open)

Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0

ISO 19011:2026 - Guidelines for auditing management systems

NIST SP 800-53A Rev. 5 - Assessing security and privacy controls

PCI SSC Document Library (PCI DSS v4.0.1)

CIS Critical Security Controls v8.1

ISO/IEC 27005:2022 - Guidance on managing information security risks

NIST SP 800-30 Rev. 1 - Guide for conducting risk assessments

NIST SP 800-115 - Technical guide to information security testing and assessment